

Secure SDLC Defense-in-Depth Plan

Cydney Goldstein

Table of Contents

SCOPE – CYDNEY GOLDSTEIN	3
REFERENCE DOCUMENTS – CYDNEY GOLDSTEIN.....	3
MANAGEMENT CONSIDERATIONS – CYDNEY GOLDSTEIN	4
SUMMARY OF PLANNED ACTIONS – CYDNEY GOLDSTEIN	7
DETAIL OF PLANNED ACTIONS – CYDNEY GOLDSTEIN	8

Scope

This Defense-in-Depth plan introduces a secure Software Development Life Cycle (SDLC) control set into the entirety of Humongous Holdings' enterprise. The goal of this plan is to establish secure SDLC governance, integrate security at every phase of the life cycle, implement configuration management, enhance vendor management, improve training and awareness processes, and create documentation measures for the SDLC. Utilizing NIST 800-53 and FIPS 200 standards, as well as the NIST CSF and RMF, a holistic SDLC procedure is to be established to provide Humongous Holdings with all physical, technical, and administrative safeguards necessary for optimal, company-wide performance.

Reference Documents

- [NIST 800-53 Rev. 5](#)
 - Catalog of security and privacy controls for federal information systems.
- [FIPS 199](#)
 - Defines security categorization levels (low, moderate, high).
- [FIPS 200](#)
 - Establishes minimum security requirements aligned with NIST 800-53.
- [NIST CSF](#)
 - Framework organized around *Identify, Protect, Detect, Respond, and Recover* processes.
- [NIST RMF](#)
 - Framework for formally categorizing, selecting, implementing, assessing, authorizing, and monitoring security controls.
- [ISO/IEC 27001](#)
 - International standard for Information Security Management Systems.
- [ISACA \(COBIT Framework\)](#)
 - Governance and management framework for IT often used in audit and compliance functions.
- [ITGC \(IT General Controls\)](#)

- Foundational IT controls over access, change management, and operations to support audit reliability.

Management Considerations

To effectively implement the proposed buildout of the software development lifecycle (SDLC), a deliberate management oversight is required across Humongous Holdings. This is to coordinate across the company, as well as third-party vendors. The following considerations outline all managerial responsibilities and governance functions to provide a holistic assurance process to the SDLC throughout the Apache Longbow TADS upgrade.

Oversight and Communication

Per NIST 800-53: PM-1- Program Management – Information Security Program Plan:

“Develop and disseminate an organization-wide information security program plan that:” ... “Includes the identification and assignment of roles, responsibilities, management commitment, coordination among organizational entities, and compliance;”.

Utilizing this standard provides the framework for a clear program manager to be established, to ensure compliance with all Humongous Holdings (HH) specific, and federal security requirements. It is inherent that HH adopts a formal practice for documentation and reporting, overcoming the informal ad-hoc practices noted. This will also establish a governance structure to regulate all SDLC reviews, sign off processes, and reporting mechanisms, as required by CA-2 and CA-6 of NIST 800-53.

Third Party Oversight

Per NIST 800-53 SA-4 – System and Services Acquisition – Acquisition Process:

“Include the following requirements, descriptions, and criteria, explicitly or by reference, using [Selection (one or more): standardized contract language;” ...” a. Security and privacy functional requirements; b. Strength of mechanism requirements; c. Security and privacy assurance requirements; d. Controls needed

to satisfy the security and privacy requirements. e. Security and privacy documentation requirements; f. Requirements for protecting security and privacy documentation; g. Description of the system development environment and environment in which the system is intended to operate; h. Allocation of responsibility or identification of parties responsible for information security, privacy, and supply chain risk management; and i. Acceptance criteria.”

Developing an “iron-clad” contract with all third-party suppliers will maintain the integrity of all COTS products acquired for use at HH. Contracts are to outline all reporting requirements, documentation, security requirements, development benchmarks, testing strategies, responsibility allocation, consequences, and acceptance criteria, agreed upon by both contractual parties. This protects HH from any third-party SDLC risks from COTS products and their operators.

Policy Formalization

Per NIST 800-53: PL-2- Planning – System Security and Privacy Plans:

“a. Develop security and privacy plans for the system that: 1. Are consistent with the organization’s enterprise architecture; 2. Explicitly define the constituent system components; 3. Describe the operational context of the system in terms of mission and business processes; 4. Identify the individuals that fulfill system roles and responsibilities; 5. Identify the information types processed, stored, and transmitted by the system; 6. Provide the security categorization of the system, including supporting rationale; 7. Describe any specific threats to the system that are of concern to the organization; 8. Provide the results of a privacy risk assessment for systems processing personally identifiable information; 9. Describe the operational environment for the system and any dependencies on or connections to other systems or system components; 10. Provide an overview of the security and privacy requirements for the system; 11. Identify any relevant control baselines or overlays, if applicable; 12. Describe the controls in place or planned for meeting the security and privacy requirements, including a rationale for any tailoring decisions; 13.

Include risk determinations for security and privacy architecture and design decisions; 14. Include security- and privacy-related activities affecting the system that require planning and coordination with [Assignment: organization-defined individuals or groups]; and 15. Are reviewed and approved by the authorizing official or designated representative prior to plan implementation.”

As of now, humongous Holdings lacks formal lifecycle policies, documentation standards, and configuration management policies in all stages of IT. It is pertinent that clear SDLC policies are developed to define roles, responsibilities, escalation paths, and reporting mechanisms across all members of the SDLC.

Resource Allocation

Per NIST 800-53: PM-3 – Program Management – Information Security and Privacy

Resources:

“Include the resources needed to implement the information security and privacy programs in capital planning and investment requests and document all exceptions to this requirement; b. Prepare documentation required for addressing information security and privacy programs in capital planning and investment requests in accordance with applicable laws, executive orders, directives, policies, regulations, standards; and c. Make available for expenditure, the planned information security and privacy resources.”

As of now, resources at HH are not being sufficiently allocated to support secure development practices. It is vital to HH’s continuation to allocate sufficient resources to ensure higher-quality software output, reduce security risks throughout the SDLC, and improve operational efficiency. Long term, this will reduce operational costs, as it minimizes defects, and in turn, minimized downtime.

Risk Management

Per NIST 800-53: PM-3 - Program Management – Risk Management Strategy:

“a. Develops a comprehensive strategy to manage: 1. Security risk to organizational operations and assets, individuals, other organizations, and the Nation associated with the operation and use of organizational systems; and 2. Privacy risk to individuals resulting from the authorized processing of personally identifiable information; b. Implement the risk management strategy consistently across the organization; and c. Review and update the risk management strategy [Assignment: organization-defined frequency] or as required, to address organizational changes.”

Developing an organization-wide, clear and holistic risk management strategy is incredibly important for the creation of a software development lifecycle. It allows for teams to spot and control threats within software in earlier stages of development, thus reducing risk of a zero-day vulnerability. It will also put procedures in place in cases of operational failure.

Summary of Planned Actions – Cydney Goldstein

Humongous Holdings operates with ad-hoc, and informal policies for software development practices, with a lack of governance functions across IT and security operations. It is noted that systems are supported until failure, documentation is lacking, and acquisitions are informal. Security checks are siloed, there are no configuration management policies in place, and testing of any product of out-sourced development is non-existent.

In order to combat Humongous Holdings’ weaknesses in their Software Development Life Cycle processes, there must be a switch from a reactive and ad-hoc decision making model, into a structured and policy-driven SDLC. This will majorly reduce both technical and administrative gaps in HH’s security processes. Once the formal SDLC policy and lifecycle governance is established, then configuration management policies can be developed, third-party vendor contract standards and policies can be developed, documentation practices can be integrated, testing and quality assurance measures will be incorporated, personnel/team collaboration policies can be enforced, a switch can be made from reactive support to proactive support processes, and metrics can be tied back to further SDLC development. These planned actions in collaboration create a holistic

approach to SDLC governance to ensure both technical and administrative controls are enforced across all of Humongous Holdings' subsidiaries and all third-party vendors as well.

The creation of said planned actions is developed from support of the FIPS 199, FIPS 200 and NIST 800-53 frameworks. First, FIPS 200 was used to take the Humongous Holdings case study and highlight major issues found throughout the entire business operation. Then, NIST 800-53 was utilized to create specifications to said controls. FIPS 199 was then utilized to designate impact levels for each control set. The controls are presented from highest impact level to lowest regarding the SDLC. Additional support is integrated using the NIST Cybersecurity Framework (CSF) and the NIST Risk Management Framework (RMF).

Detail of Planned Actions

Establish Secure SDLC Policy – Impact Level = HIGH

Issue: Within Humongous Holdings' case presented, there is no documented lifecycle policy, as it is noted that “all systems are fully supported until they become too big a pain to maintain”. It is also noted that lifecycle documentation “is neither produced, nor updated”. Without governance of the software development lifecycle, there is nothing to bind teams to minimum controls, documentation practices, nor acceptance criteria. This can cause insecure software deployments, an illegible audit trail, and inconsistent decision making across subsidiaries.

Solution: Establish a formal Secure Software Development Lifecycle policy with governance and accountability baked in. Define all phases, roles, mandatory documentation artifacts, verification measures, and exception processes across all hosted and embedded models. Integrate touchpoints in the already imbedded RAM Platform that manages outreach across all subsidiaries. Require board approval for development of SDLC and major SDLC changes. Continue the CISO accountable quarterly reporting for SDLC governance. Mandatory policy training for all managers, developers,

and operations staff, ensuring the acknowledgement and complete understanding of the SDLC policy. Discontinue ad-hoc training practices. Maintain quarterly internal audits tied to metrics already collected in HH's current security practice.

Guiding Framework: NIST 800-53: PL-2, SA-3; CSF *Identify* (Governance, Risk Management); RMF Step 1 – *Categorize*, Step 2: *Select*; FIPS 200- *Information System Impact Levels* and *Minimum Security Requirements*.

Implement Enterprise-Wide Configuration Management – Impact Level = HIGH

Issue: It is noted that Humongous Holdings does not deploy any form of configuration or change management. This can cause uncontrolled modifications, issues with version rollout, and miscommunications across all IT-related subsidiaries.

Solution: Implement a configuration management database to track all configuration items, map relationships between assets, document all changes, and support total IT lifecycle processes such as incident response. Define and enforce baseline configurations for both front-end and back-end tiers. Create a Request For Change workflow with impact analysis and rollback mechanisms baked in. Automate monitoring for configuration deviation.

Guiding Framework: NIST 800-53: CM-2, CM-3, CM-6; CSF *Protect* (Configuration Management); RMF Step 3 – *Implement*; FIPS 200 *Minimum Security Requirements* (Configuration Management).

Formalize Secure Acquisition Processes for Third-Party Vendors- Impact Level = HIGH

Issue: Vendor collaboration is noted to be acquired through “form letter contracts”, with no formal process integrated. HH's vendor selection process is limited to “people they've dealt with before”. There is no acceptance testing of acquired software and no management oversight. This creates a high-risk environment for the integration of compromised components entering the environment and leaves gaps in contracts between HH and third-party vendors. Additionally, acquired internal software is deployed

in an “open the box and install” method, as it is noted there are no resources allocated to perform verification measures. This can lead to an exploit of the third-party attack surface.

Solution: Formalize a secure acquisition and supply chain risk management policy across HH. This includes contract drafting with security clauses of secure development, vulnerability disclosure, patch SLAs, incident reporting, and audit rights to all software development projects being outsourced. It should also be made required that the third-party vendor provides a software bill of materials for all delivered software. All third-party vendors will be assessed in annual security reviews, with elevated scrutiny in COTS software owners. All third-party vendors will require the usage of a VPN through Humongous Holdings while developing the project, and there will be a prohibition of “open the box and install” style deployments.

Guiding Framework: NIST 800-53: SA-9, SR-3, SR-5; CSF *Identify* (Supply Chain Risk Management); RMF Step 2 – *Select*, Step 4 - *Assess*; FIPS 200 *Minimum Security Requirements* (System and Services Acquisition)

Enforce Documentation Standards – Impact Level = HIGH

Issue: The maintenance manager noted that documentation is not produced after the installation of a Humongous Holdings product. It is also noted that lifecycle documentation is not produced or updated regularly. This disrupts the auditing process, the incident investigation process, and creates a disorganized environment for patch deployment.

Solution: Enforce lifecycle-wide documentation standards that have centralized storage for appropriate role-based access. Create documentation policies for requirements, design, testing plans, testing results, deployment records, and enterprise-wide implementation controls for all surfaces of the SDLC. Collect everything in a centralized repository, organized in an accessible manner so documentation can be accessed appropriately by both headquarters and subsidiary offices. Include current network topology diagrams, segmentation maps, and VPN architectures for every network link

utilized on each project. Tie documentation to configuration management approvals and release gates as well.

Guiding Framework: NIST 800-53 PL-8, SA-5; CSF *Identify* (Asset Management); RMP Step 5 – *Authorize*; FIPS 200 *Minimum Security Requirements* (Planning).

Embed Security into Every SDLC Phase – Impact Level = HIGH

Issue: Security is noted to be fully deployed and monitored for “mission critical elements”. There is no integrated security into any form of IT governance, documentation, or reporting mechanisms. This can create an environment for vulnerabilities to persist in critical and non-critical systems. In addition, if security elements are not present throughout each SDLC level, threat modeling and testing can be inconsistent.

Solution: Integrate DevSecOps approach. Establish secure coding guidelines for Java and all integration components on the VPN stack. Integrate both static and dynamic application security testing into continuous integration to ensure test coverage across all units of the software development. Require threat modeling within the RAM Platform through the authentication, authorization, data protection, and network interaction surfaces. Conduct regular penetration testing on both internal and third-party functions that is oriented towards mission-critical and administrative systems alike.

Guiding Frameworks: NIST 800-53: SA-11, RA-3, RA-5; CSF *Protect* (Secure Development), *Detect* (Testing); RMF Step 3 - *Implement*, Step 4 – *Assess*; FIPS 200 *Minimum Security Requirements* (System and Information Integrity).

Apply Uniform SDLC Security and Testing Standards – Impact Level = MODERATE

Issue: Testing is done at the unit and integration level of software development and is conducted by developers with little to no administrative oversight. This can cause defects to be maintained into production phases and be integrated into the final product.

Solution: Formalize quality assurance and testing standards across subsidiaries. Include firewall and VPN penetration practices. Create a dedicated security quality assurance

team that is independent of software developers. Have said team perform unit, integration, system, performance, security, and user acceptance testing across all systems, not just those that are mission critical. Integrate routine vulnerability assessment created after penetration testing that is mapped for trends utilizing documented metrics from the QA/PT analyses.

Guiding Frameworks: NIST 800-53 RA-5, SA-11; CSF *Detect* (Testing, Vulnerability Management); RMF Step 4 – Assess; FIPS 200 *Minimum Security Requirements* (Risk Assessment).

Improve Formal Communication – Impact Level = MODERATE

Issue: It is noted that the software development team is divided, where “hot shots” are those who develop new projects, while there is designated patching staff to handle patch deployment and non-creative aspects of development. There is no communication between these groups. There is also a large separation between the security and all other IT departments. This can lead to uneven quality in produced software and project critical miscommunications.

Solution: Improve communication and collaboration efforts across teams, third-party vendors, and subsidiaries. Create integrated project owning that allows specialized teams to become “experts” on their development project, as determined by role description. Have weekly meetings with teams, discussing development, and monthly summits across team leaders to maintain project alignment.

Guiding Frameworks: NIST 800-53: AT-2, PM-9; CSF *Identify* (Governance, Workforce); RMF Step 6 – *Monitor*; FIPS 200 *Minimum Security Requirements* (System and Communication Protection).

Implement Proactive Lifecycle Management – Impact Level = MODERATE

Issue: Humongous Holdings currently has a general process of systems being supported until they become “too big a pain to maintain”. Then support is dropped from said system. There is no lifecycle timeline, and thus no lifecycle documentation of all software

processes in this light. This can lead to unplanned downtime, higher remediation costs, and an inconsistent risk posture throughout all subsidiaries.

Solution: Implement proactive lifecycle management process. This includes defining support timelines and developing formal retire criteria for both software and documentation processes alike. Standardize software patch development and implementation procedures prior to the release. Tie metrics to incidents already collected and maintained in repository to develop proactive lifecycle procedures that are best suited for Humongous Holdings. Schedule patch cycles for routers, firewalls, and VPN gateways across all subsidiaries. Share SIEM dashboards and change timeline calendars across subsidiaries.

Guiding Frameworks: NIST 800-53: SI-2, MA-2; CSF *Protect* (Maintenance, Patch Management), RMF Step 6 – *Monitor*; FIPS 200 *Minimum Security Requirements* (Maintenance, Planning).

Adopt Agile-Waterfall Model – Impact Level = LOW

Issue: The Waterfall model of the SDLC is deployed currently at HH. However, lifecycle stages are noted not to be strictly followed, documentation is missing, ad-hoc practices seem to override the structure, and there is a divide between what is deemed mission-critical and non-mission critical, which leaves attack surfaces neglected. This can cause risks to accumulate across all phases of the SDLC.

Solution: Adopt an Agile-Waterfall method to software development that includes verification gates. Mandate creation of verified artifacts at each development phase, encompassing design, requirements, test plans, and security assessments. Enforce verification gates with objective evidence before progressing through the SDLC stages that includes security integration. Maintain quarterly security summits to moderate risks and integrate security summit procedures in the case of rapid issue escalation. Align change management procedures with RAM workflows.

Guiding Frameworks: NIST 800-53: SA-3, PL-8; CSF *Identify* (Governance, Project Management); RMF Step 3 – *Implement*, Step 4 - *Assess*; FIPS 200 *Minimum Security Requirements* (Planning).

Tie Metrics to SDLC for Improvement – Impact Level = LOW

Issue: Humongous Holdings collects in-depth security metrics to allocate resources and guide decision making. However, these metrics are not integrated in the SDLC lifecycle for continuation in development. This leaves a large gap for continuous improvement that could be heavily utilized.

Solution: Tie metrics to lifecycle improvement decisions. Map each metric to its prospective SDLC phase and control set. Define action thresholds that can trigger change requests, additional testing requests, or control enhancements. Include harvested metrics within the CISO's quarterly security report to the board, and in all security summit agendas. Metrics can also be used to perform network hardening of firewalls and VPNs.

Guiding Frameworks: NIST 800-53: CA-7, SA-11; CSF *Detect/Respond* (Improvements); RMF Step 6 – *Monitor*; FIPS 200 *Minimum Security Requirements* (Planning, Risk Assessment).